

Módulo 1. Seguridad en redes

1.3 Sistemas de detección de intrusos

Tipos de intrusos

■ **Impostor** (*masquerader*)

- Individuo sin autorización que se introduce en los sistemas de control de acceso de un sistema para explotar la cuenta de un usuario legítimo

■ **Infractor** (*misfeasor*)

- Usuario legítimo que accede a datos, programas o recursos a los que no está autorizado, o que está autorizado pero hace mal uso de sus privilegios

■ **Usuario clandestino**

- Individuo que se apodera del control de supervisión del sistema y lo usa para eludir los controles de auditoría y acceso

Ejemplos de intrusiones

- **Obtener acceso** como administrador a un servidor de correo
- **Desfigurar** (*deface*) una página *web*
- Adivinar o **descifrar contraseñas**
- **Copiar** una **base de datos** con números de tarjetas de crédito
- **Ver datos sensibles**, como registros de nómina o información médica, sin autorización
- Ejecutar un analizador de paquetes para **capturar nombres de usuarios y contraseñas**
- Usar un error de permisos en un servidor FTP anónimo para distribuir ficheros pirateados
- **Hacerse pasar por un empleado** y llamar a soporte para restablecer su contraseña de correo y obtener la nueva
- Usar sin permiso un equipo desatendido con sesión iniciada

Ataques internos

- Están entre los más difíciles de detectar y evitar
- Pueden ser motivados por venganza o, simplemente, porque el usuario cree que está en su derecho
- **Contramedidas:**
 - Establecer **política de mínimo privilegio**, a los usuarios solo se les permite acceso a los recursos necesarios para realizar su trabajo
 - **Generar registros** de lo que hacen los usuarios y a qué acceden
 - **Proteger los recursos sensibles** con autenticación fuerte
 - Tras finalizar el contrato, eliminar el acceso al sistema y a la red
 - Hacer una copia del disco duro para usarla como evidencia en caso de que información de la compañía acabe en un competidor

Técnicas de intrusión

- Una técnica de intrusión es un **conjunto de actividades** que tienen por **objetivo violar la seguridad de un sistema informático**
- El objetivo del intruso es:
 - Conseguir **acceso al sistema**
 - O **incrementar el rango de privilegios accesibles** en un sistema (escalada de privilegios)
- La mayoría de los ataques **usan vulnerabilidades del sistema o de los programas** para permitir a un usuario ejecutar código que abre una puerta trasera al sistema



Detección de intrusos

Sistema de detección de intrusos (IDS)

- Son sistemas que **detectan un uso no autorizado de un computador, una red o una infraestructura de comunicaciones**
 - Si lo detectan disparan una alarma y/o toman medidas adicionales
 - E-mail al administrador
 - Cambiar reglas en la lista de control de acceso del cortafuegos
 - Cerrar una conexión
- Constan de:
 - **Sensores:** recogen el tráfico de red o la actividad de usuario
 - **Analizadores:** analizan los datos capturados en busca de actividad sospechosa
 - **Interfaces con el administrador:** se encargan de enviar las alertas
- Los IDS **por sí mismos no pueden impedir que ocurra el ataque**
 - Cuando el IDS avisa, el ataque ya ha tenido lugar



IDS: Objetivo



**Tasa de
detección
de intrusiones**



**Tasa de
Falsas alarmas**



Las falsas alarmas son muy costosas
Los administradores de sistemas invierten mucho tiempo analizando los datos

IDS: Características

- Es la **segunda línea de defensa** del sistema (defensa en profundidad)
- Se basa en la suposición de que **el comportamiento del intruso difiere del de un usuario legítimo** de manera **cuantificable**
- Si la intrusión se detecta suficientemente rápido, el intruso puede ser identificado y expulsado del sistema antes de que realice algún daño
- Un sistema de detección de intrusos efectivo, **puede servir como disuasión**, evitando las intrusiones
- La detección de intrusos **permite obtener información** sobre técnicas de intrusión

Tipos de IDS

Se pueden clasificar en función de:

La información que escuchan y analizan

- ✓ HIDS
- ✓ NDIS

Modo en el que analizan la información

- ✓ Basado en reglas (firmas)
- ✓ Basado en anomalías

La respuesta que dan

- ✓ Respuestas activas
- ✓ Respuestas pasivas

Tipos de IDS

En función de la información capturada:

- **HIDS** (Host IDS): Son sistemas que buscan **si existe actividad inapropiada en un host**

- Detectan borrado de ficheros y modificación de la configuración del sistema
- Se instalan en servidores críticos



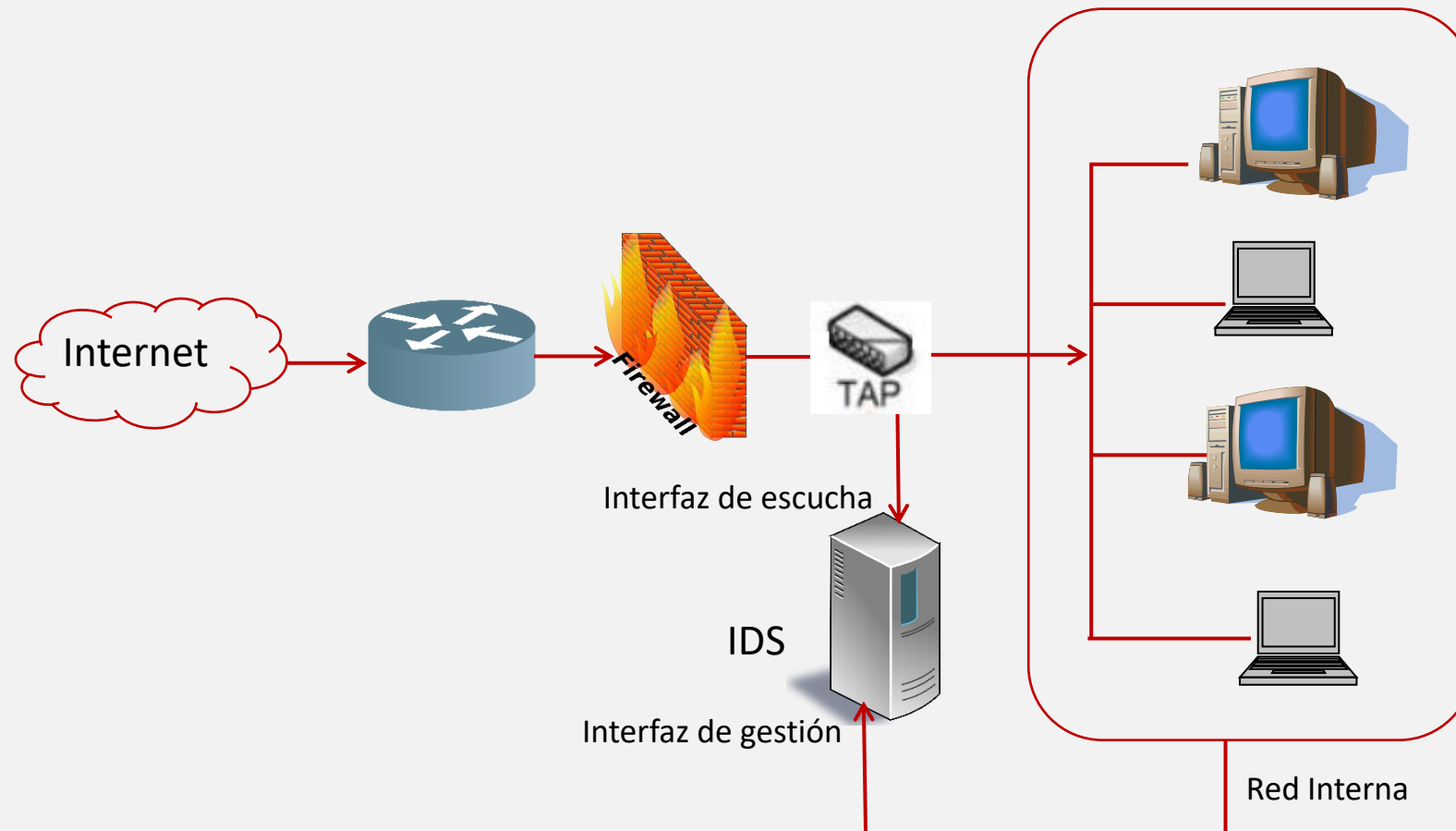
- **NIDS** (*Network IDS*): Son sistemas que **escuchan el tráfico de una red** en busca de comportamientos sospechosos

- Para poder escuchar el tráfico de la red es **necesario redirigir el tráfico al IDS**
- Pueden ser computadores con un software específico o hardware dedicado
- Su tarjeta de red estará en modo promiscuo, capturando todo el tráfico y mandando una copia al analizador
- Solo puede monitorizar tráfico de red, nunca la actividad dentro de un computador



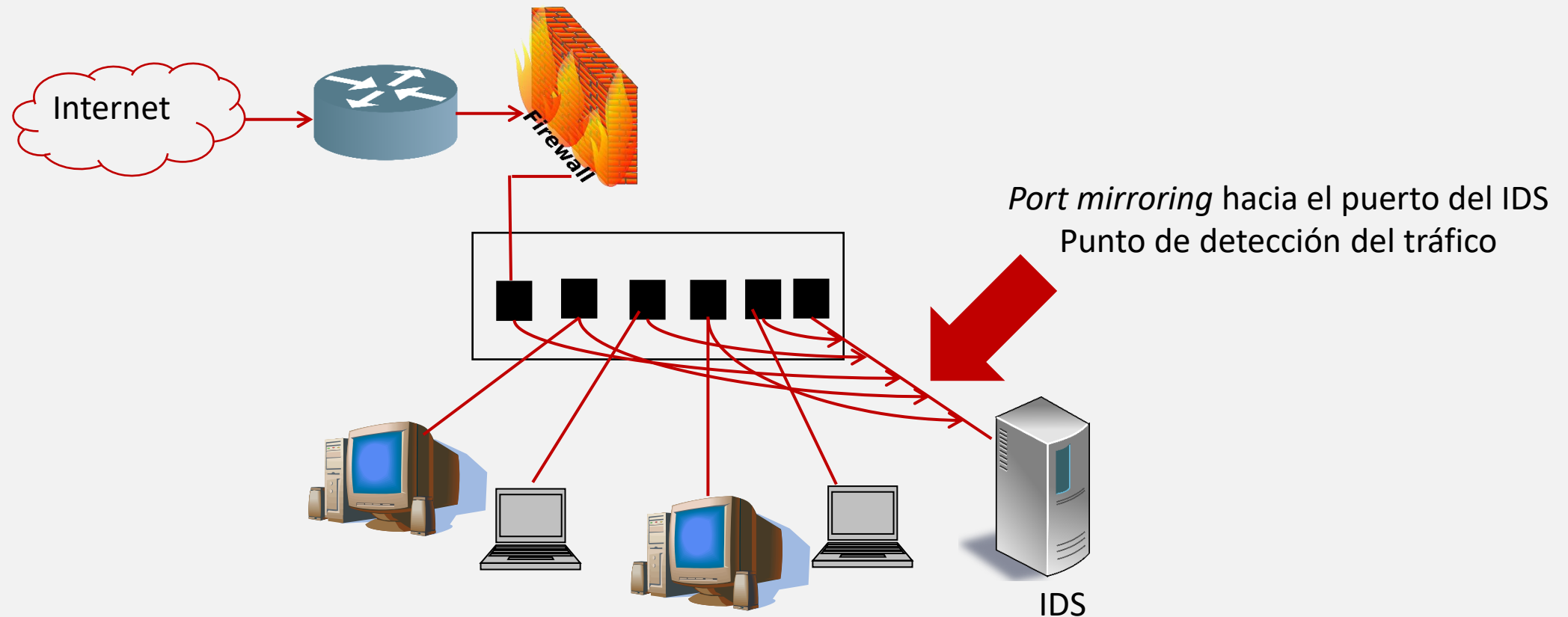
Despliegue NIDS mediante Tap

- *Tap*: Dispositivo pasivo de red que duplica el tráfico que recibe para enviarlo a dos destinos



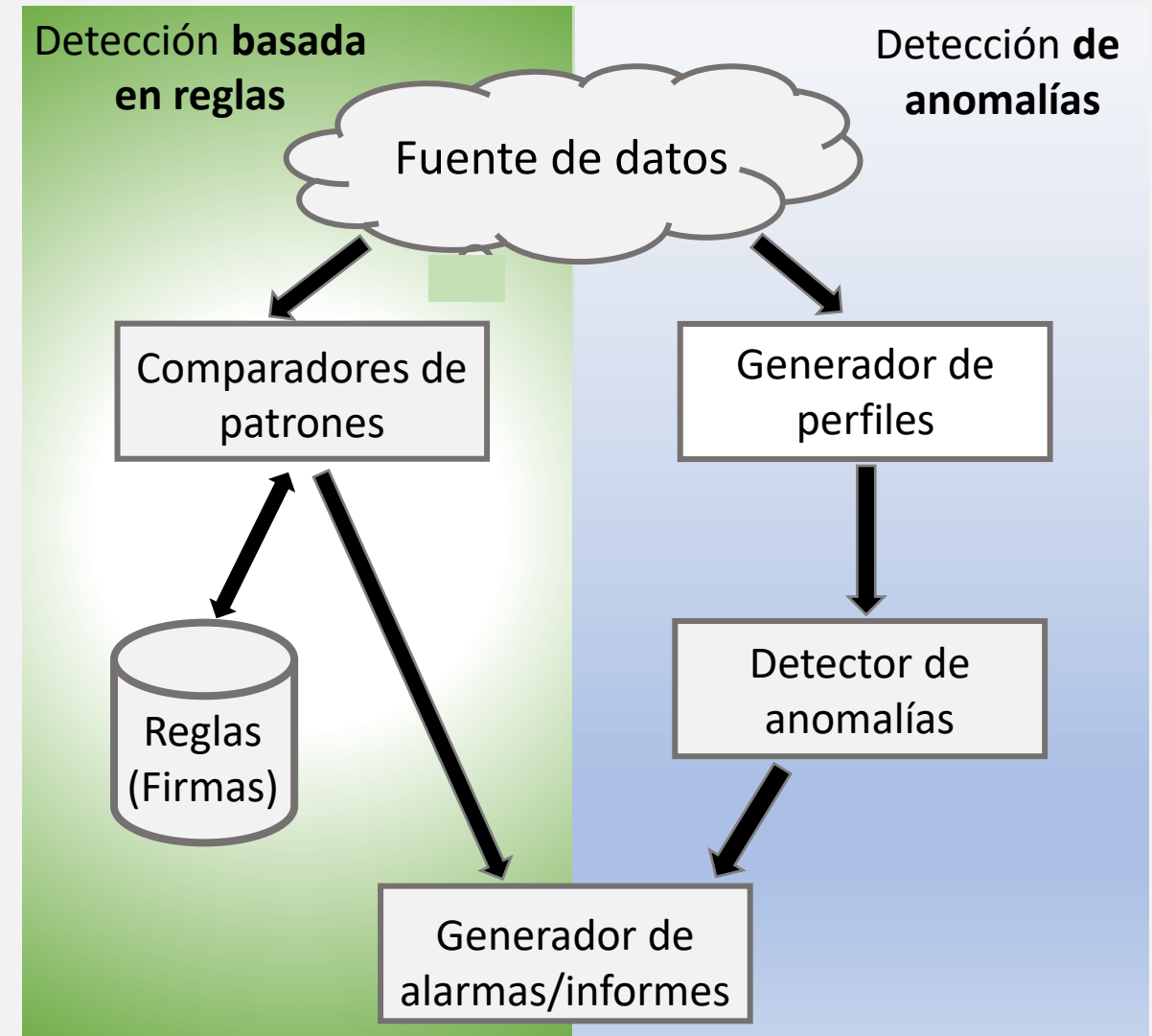
Despliegue NIDS con *port mirroring*

- Todo el tráfico que pasa por el switch se copia para poder ser enviado al puerto del IDS



Tipos de IDS (según el tipo de análisis)

- El funcionamiento del IDS se basa en la suposición de que **el comportamiento del intruso difiere del de un usuario legítimo** de manera **cuantificable**
- Dos maneras de abordar el análisis:
 - Detección de anomalías
 - Detección basada en reglas



Detección de anomalías

■ Funcionamiento

- Fase de aprendizaje: crear un **perfil del comportamiento normal** a partir de datos relacionados con el comportamiento de los usuarios legítimos
 - Es importante establecer **umbrales adecuados para reducir los falsos positivos**
 - Este perfil se tiene que **actualizar con frecuencia**
- **Detectan desviaciones del comportamiento** normal a partir de un análisis estadístico
 - Pueden ser capaces de detectar ataques nuevos, sobre los que no hay información conocida

Ejemplo para crear el perfil

- ✓ Número de ocurrencias de un evento por unidad de tiempo
- ✓ Tiempo transcurrido entre eventos
- ✓ Frecuencia de utilización de recursos
- ✓ ...



Para cada variable establecer el valor (umbral) a partir del cual salta la alarma

Detección de anomalías

Limitaciones

✓ Falta de datos de entrenamiento

- ✓ Gran cantidad de datos de funcionamiento normal de red o sistema y pocos datos que contengan ataques reales o anomalías

✓ Cambio gradual

- ✓ Los métodos estadísticos detectan cambios en el comportamiento, pero el atacante puede actuar gradual e incrementalmente

✓ Muchos falsos negativos

- ✓ Un ataque puede estar dentro de los límites del comportamiento normal

✓ Muchos falsos positivos, que son muy costosos

- ✓ Los administradores pasan mucho tiempo examinando pruebas

Detección basada en reglas (firmas)

■ Funcionamiento

- Se tienen **almacenadas** un conjunto de **reglas o patrones de ataques conocidos** (firmas)
 - A menudo, las reglas se desarrollan analizando herramientas de ataque recogidas en Internet
 - Las reglas son muy específicas de sistemas y ataques
 - Se pueden complementar con reglas generadas por el personal de seguridad
- Para decidir si un comportamiento dado es una intrusión **se compara con las firmas almacenadas**

Limitaciones

- ✓ No detectan ataques nuevos porque su firma no es todavía conocida

Detección basada en reglas (firmas)

Ejemplo de firmas

- ✓ Un paquete de red con muchas instrucciones NOP  **Explotación *buffer overflow***
- ✓ Muchos paquetes TCP SYN seguidos  **TCP SYN flooding**
- ✓ Un paquete con la misma IP origen y destino  **LAND attack**
- ✓ Un paquete ICM Request con la dirección destino de broadcast  **Smurf attack**
- ✓ ...

Tipos de IDS (en función de su respuesta)

■ Pasivos:

- Almacenan información y envían alerta
- **No hacen nada por impedir el ataque**



■ Activos (IPS intrusion prevention system):

- Incluyen todas las funcionalidades de los IDS
 - Por eso también se suelen llamar IDPS
- **Realizan acciones para detener el ataque**
 - Pueden reprogramar el firewall para que bloquee el tráfico que forma parte del ataque



+



SNORT

¿Qué es SNORT?

- Es un **IDS** de red (**NIDS**) basado en reglas
- Implementa un motor de detección de ataques y barrido de puertos basado en reglas
 - Si detecta el patrón de un ataque conocido, incluido en sus reglas, genera una alarma y/o una determinada respuesta
 - Dispone de una gran cantidad de **conjuntos de reglas predefinidas**
 - Para detectar Backdoors, DDos, fingerprinting, ftp, ataques web, escaneos nmap
 - Se pueden **incorporar nuevas reglas**
 - Lenguaje de creación de reglas flexibles, potente y sencillo
 - Actualizaciones constantes que incorporan nuevos ataques
 - Todo esto **en tiempo real**

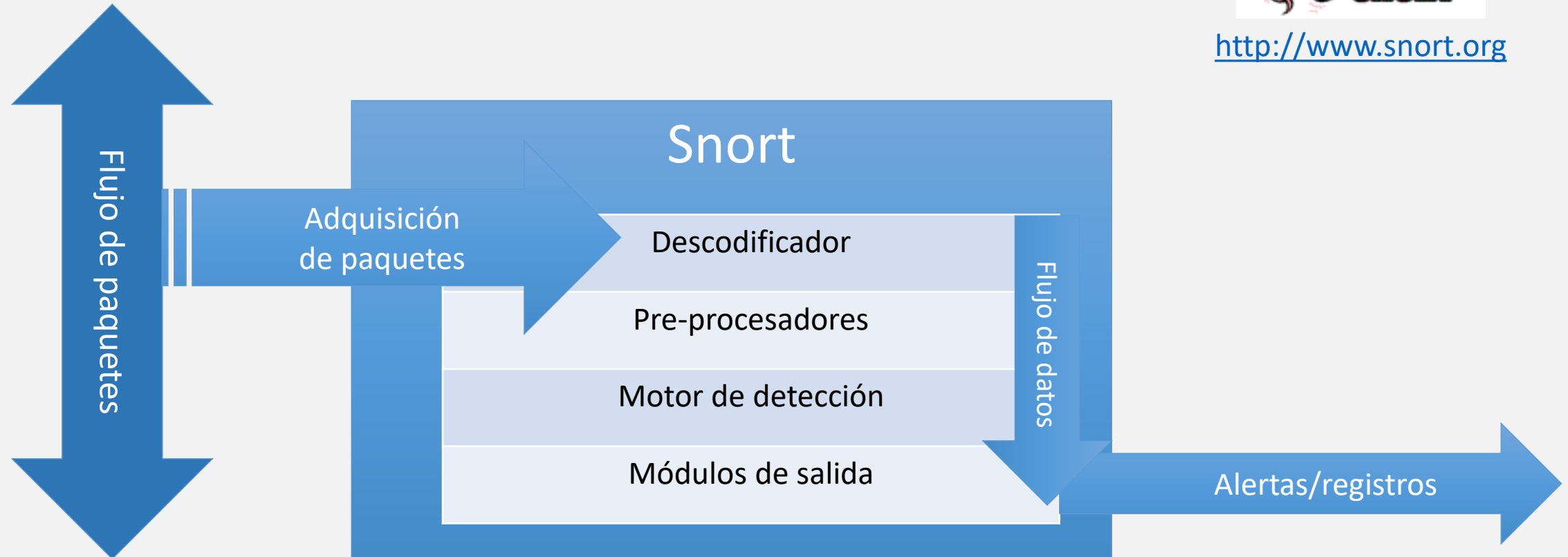
¿Cómo funciona Snort?

- Puede funcionar como:
 - **Sniffer:** podemos ver en consola y en tiempo real qué ocurre en nuestra red
 - **Registro de paquetes (*Packet Logger*):** permite guardar en un archivo los logs para su posterior análisis
 - **NIDS:** Realiza detección y análisis del tráfico de red
- Se puede configurar como NIPS

Arquitectura



<http://www.snort.org>



Componentes

■ Descodificador de paquetes

- Descodifica los paquetes a nivel de capa de enlace (Ethernet), capa de red, capa de transporte ...

■ Pre-procesadores

- Detectan anomalías de protocolos en las cabeceras
- Desfragmentan los paquetes IP y re-ensamblan los flujos TCP
- Descodifican los protocolos de aplicación (HTTP, SMTP, POP, IMAP, FTP, Telnet, SSH, DNS, SSL/TLS...) para inspeccionarlos y detectar ataques (*exploits*)
- Detectan suplantación ARP y exploración de redes

■ Motor de detección

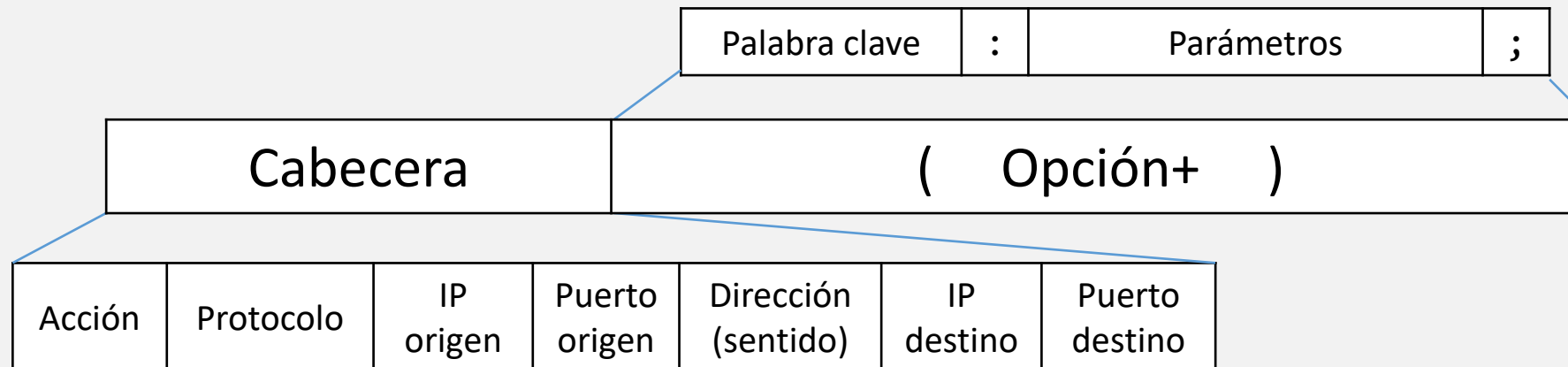
- Aplican reglas a los paquetes

■ Módulos de salida

- Generan alertas y registros

Reglas

- Contiene los mensajes de alerta e información sobre qué se debe buscar en el mensaje para decidir si se ejecuta la acción especificada



Ejemplos:

```
alert ip any any -> any any (msg:"IP packet");
alert tcp any any -> any any (msg:"SYN packet"; flags:S;)
```

Cabecera de regla

Acción	Protocolo	IP origen	Puerto origen	Dirección (sentido)	IP destino	Puerto destino
--------	-----------	-----------	---------------	---------------------	------------	----------------

- Las **acciones** suelen ser:
 - alert: genera una alerta y registra el paquete
 - log: registra el paquete
 - drop: descarta y registra el paquete (modo en línea)
 - sdrop: descarta el paquete sin registrarlo (modo en línea)
- El **protocolo** puede ser TCP, UDP, ICMP e IP
- Las **direcciones IP**, en notación CIDR, pueden ser any, negaciones (!) y listas separadas por comas ([])
- Los **puertos** pueden ser any, números, rangos (N:M) y negaciones
- El **sentido** puede ser -> o <>

Opciones de regla

Palabra clave	:	Parámetros	;
---------------	---	------------	---

- Para **proporcionar información** sobre la regla
 - msg: mensaje a imprimir con la alerta o registro
 - sid, rev: identificador de regla y número de revisión
- Para **buscar en las cabeceras** de protocolos
 - ipopts: opciones IP activas
 - icmp_id, icmp_seq: identificador y secuencia de un mensaje ICMP ECHO
 - flags: indicadores TCP activos
- Para **buscar contenido** en los datos (interrelacionadas)
 - content: contenido a buscar
 - depth, offset, distance, within: parámetros de búsqueda
- Para **establecer condiciones** para que la regla se active
 - detection_filter: tasa a exceder por un sistema para que se dispare la alerta

Procesado de eventos

- **Filtros de tasa:** cambian la acción de una regla cuando el número o tasa de eventos indica un posible ataque
 - **Filtros de eventos:** reducen el número de eventos generados (ej. para reducir falsas alarmas)
 - *detection_filter*: define una tasa que debe ser superada por un host de origen o destino antes de que una regla pueda generar un evento.
 - ✓ Sintaxis: **detection_filter: track <by_src|by_dst>, count <c>, seconds <s>** (campo opciones de la regla)
- 
- La alerta se disparará si se detectan c paquetes de este tipo procedentes de IP_src o con destino IP_dest durante un periodo de s segundos
- **Supresión de eventos:** suprimen completamente el registro de los eventos no interesantes

Modos de Operación

- **Pasivo** (por defecto o config `policy_mode:tap`)
 - Actúa como NIDS
 - Se ignoran las reglas drop (o `-treat-drop-as-alert`)
 - Conectado a un puerto espejo (o monitor, SPAN...) de un *switch*
- **En línea** (config `policy_mode:inline` or `snort -Q`)
 - Actúa como NIPS, permitiendo que se disparen las reglas drop
 - Conectado como un cortafuegos, con dos interfaces de red
- **Prueba en línea** (config `policy_mode:inline_test` or `snort --enable-inline-test`)
 - Emula el modo en línea sin afectar al tráfico (para evaluación)
 - Las reglas drop se disparan como alertas Wdrop (*Would Drop*)

Ejemplos reglas Snort

```
alert tcp any any -> any any (msg: "Land attack detected"; flag:S; sameip; sid:5000000;rev:1;)
```

```
alert tcp any any -> 192.168.1.3 any (msg:"TCP SYN flood attack detected"; flag:S; detection_filter:track by_src, count 30, seconds 60; sid: 50000001;rev:1;)
```

```
alert tcp $EXTERNAL_NET any -> $HOME_NET 21 (msg:"ET FTP FTP STOR command attempt without login"; flow:established,to_server; flowbits:isnotset,ET.ftp.user.login; content:!"USER"; depth:4; content:"STOR"; nocase; classtype:attempted-recon; sid:2010740; rev:2;)
```

Sistemas SEÑUELO (*Honeypots*)

Sistemas señuelo (*Honeypots*)

- **Sistemas señuelo** diseñados para atraer a los atacantes
 - Aleja a los atacantes de los sistemas críticos
 - Recoge información acerca de la actividad del atacante
 - Anima al atacante a permanecer en el sistema lo suficiente para que los administradores puedan responder
- No tienen valor de producción
 - Se rellenan con información diseñada para parecer valiosa pero a la que un usuario legítimo del sistema no accedería
 - Cualquier intento de comunicarse con el sistema lo más probable es que sea un sondeo, exploración o ataque

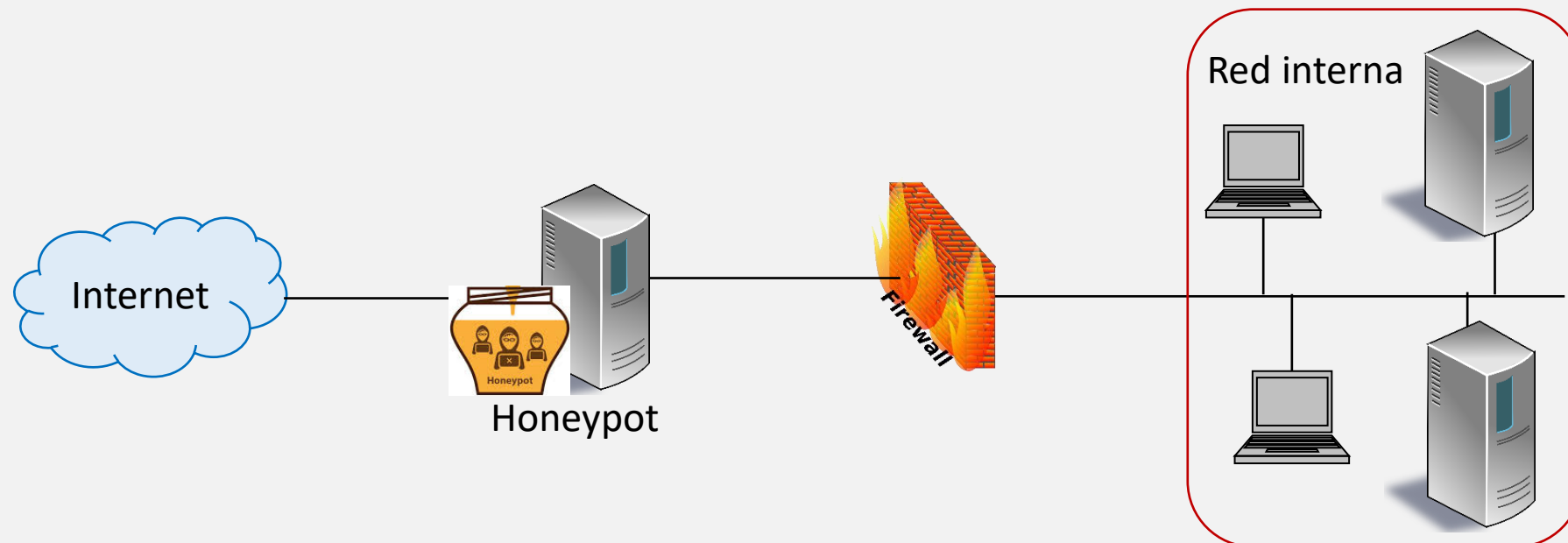


¿Dónde colocar los Honeypots?

- Existen distintas zonas donde se puede colocar un Honeypot. La decisión de dónde colocarlo dependerá de distintos factores, como:
 - El tipo de información que la organización quiere conseguir
 - El nivel de riesgo que puede tolerar para conseguir la mayor cantidad de información posible sobre los atacantes
- Vamos a analizar tres posibles localizaciones:
 - **Delante del firewall**
 - **En la zona desmilitarizada (DMZ)**
 - **En la red interna**

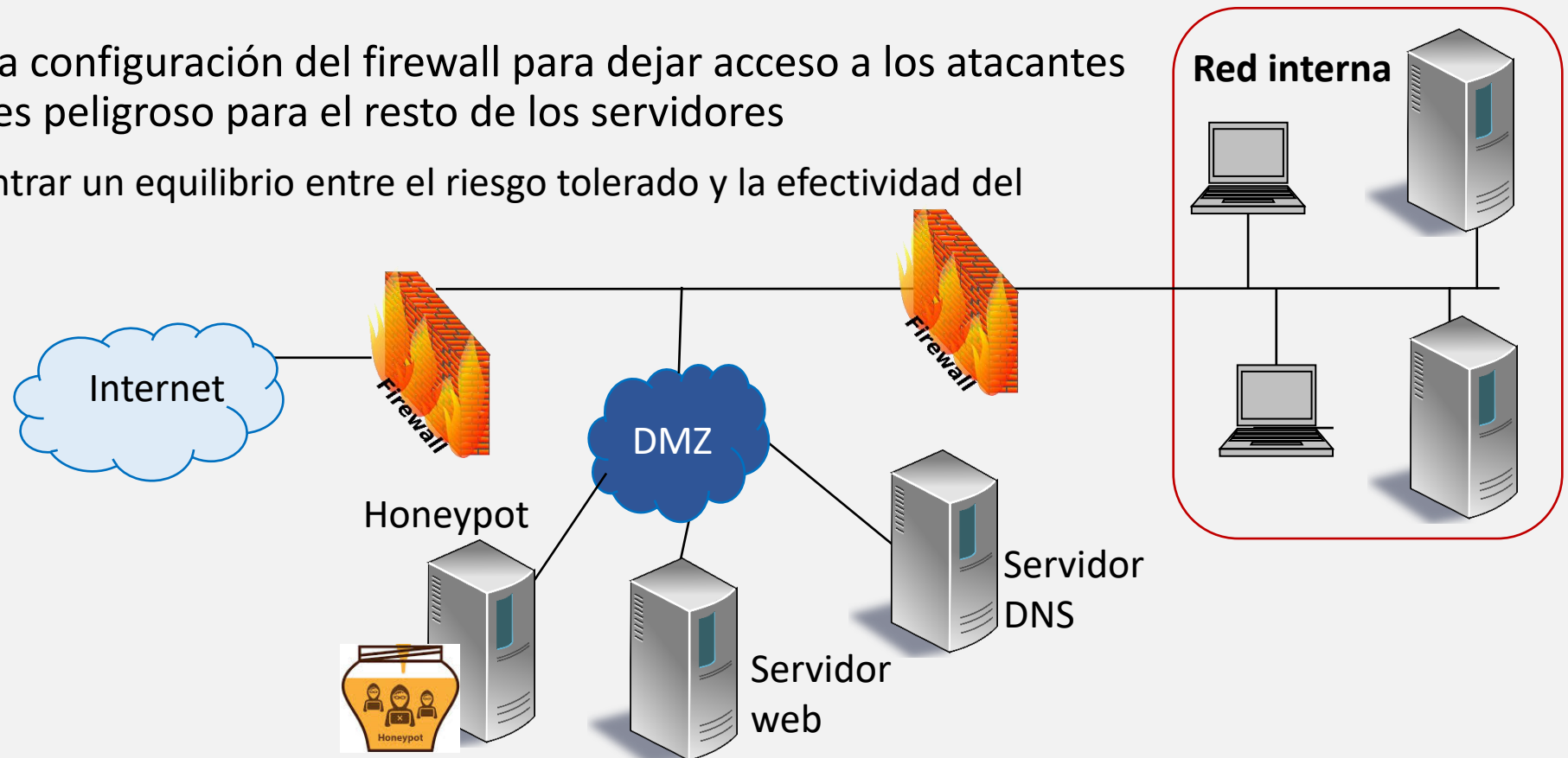
Honeypot delante el firewall

- Atrae a muchos potenciales atacantes, por lo que disminuye el trabajo del firewall y las alertas del IDS
- No incrementa el riesgo de que la red interna se vea comprometida
- Desventajas:
 - No podremos atrapar atacantes internos



Honeypot en la DMZ

- Los otros sistemas de la DMZ deben estar protegidos contra cualquier actividad generada por el Honeypot
- Desventajas:
 - Requiere relajar la configuración del firewall para dejar acceso a los atacantes a la DMZ, lo que es peligroso para el resto de los servidores
 - Hay que encontrar un equilibrio entre el riesgo tolerado y la efectividad del Honeypot



Honeypot en la red interna

- Permite capturar atacantes internos
- Pueden detectar fallos de configuración en el firewall
- Desventajas:
 - Otros sistemas internos pueden ser atacados
 - Requiere relajar la configuración del firewall para dejar acceso a los atacantes a la red interna, lo que compromete la seguridad de la red

